

VestiFlow — Guida operatore, proprietario e sviluppatore

Versione documento: 1.1 — Giugno 2026

Destinatari: operatori piattaforma VestiFlow (`isPlatformAdmin`), proprietario del prodotto, sviluppatori che mantengono il gestionale.

Visibilità: accessibile solo come **Guida tecnica** (`/app/admin/guide`) con account il cui email è in `PLATFORM_ADMIN_EMAILS` . I clienti negozio usano la voce **Guida** (`/app/guide`) con il manuale operativo del negozio.

Indice operatore

1. [Ruolo operatore piattaforma](#)
 2. [Architettura e stack](#)
 3. [Modello multi-tenant](#)
 4. [Struttura repository](#)
 5. [Ambiente di sviluppo locale](#)
 6. [Variabili d'ambiente](#)
 7. [Onboarding nuovo cliente \(tenant\)](#)
 8. [Autenticazione e ruoli](#)
 9. [Integrazione Shopify \(tecnica\)](#)
 10. [Supabase: database, Auth, Storage, RLS](#)
 11. [Dominio dati principale](#)
 12. [API e permessi tenant](#)
 13. [Import ed export CSV](#)
 14. [Scanner barcode](#)
 15. [Generazione guide \(HTML/PDF\)](#)
 16. [Build, test e CI](#)
 17. [Deploy produzione](#)
 18. [Sicurezza e checklist pre-release](#)
 19. [Troubleshooting tecnico](#)
 20. [Limitazioni note e roadmap](#)
-

1. Ruolo operatore piattaforma

L'**operatore piattaforma** (tu, come proprietario/sviluppatore) non coincide con il **Titolare** di un tenant negozio.

Concetto	Dove vive	Come si ottiene
Platform admin	Flag <code>isPlatformAdmin</code> nel profilo utente API	Email in <code>PLATFORM_ADMIN_EMAILS</code> (backend)
Titolare tenant	Ruolo <code>owner</code> nel DB tenant	Scelto al provisioning in Nuovo cliente
Ruoli negozio	<code>owner</code> , <code>admin</code> , <code>manager</code> , <code>clerk</code>	Assegnati al create tenant; non modificabili self-service oggi

Cosa vede un platform admin in UI

- Voce menu **Nuovo cliente** (`/app/admin/clients/new`)
- **Guida tecnica** in fondo alla sidebar (`/app/admin/guide`)
- Stesse schermate operative del tenant quando accedi con un account associato a un tenant

Backend

Endpoint sotto `/api/v1/admin/tenants` protetti da `JwtAuthGuard` + `PlatformAdminGuard` (verifica email contro env).

2. Architettura e stack

Componente	Tecnologia	Ruolo
Frontend	Angular 21+ (standalone, signals, OnPush)	SPA/PWA gestionale
Hosting frontend	Firebase App Hosting (o equivalente static)	CDN + HTTPS
Backend API	NestJS	Business logic, Shopify OAuth, webhook
Hosting API	Railway (tipico)	Node 22, env secrets
Database	PostgreSQL via Supabase	Dati multi-tenant
Auth	Supabase Auth (JWT HS256)	Login email/password, MFA opzionale
Storage immagini	Supabase Storage bucket <code>product-media</code>	Upload media prodotti
E-commerce	Shopify Admin API + webhook	Catalogo, stock, ordini, clienti

Regola: il frontend **non** contiene secret Shopify né service role Supabase. Tutto passa dall'API.

3. Modello multi-tenant

- Ogni **tenant** = un'azienda cliente = **un shop Shopify** collegato.
- Isolamento dati: colonna `tenantId` su entità business; filtro obbligatorio lato API.
- **Location** ≠ **Store**: lo stock è per location (semantica Shopify); lo store è entità commerciale.
- **Variante** = unità minima inventario (SKU univoco interno).
- **Due shop Shopify distinti** → **due tenant** VestiFlow separati.
- **Più location nello stesso shop** → un tenant, N location sincronizzate.

4. Struttura repository

```
vestiflow/
├── src/app/           # Frontend Angular
│   ├── core/         # Auth, guards, permissions, HTTP
│   ├── shared/       # Componenti UI riutilizzabili
│   ├── features/     # Feature lazy-loaded (products, inventory, admin, guide...)
│   └── layout/       # Shell sidebar + topbar
├── api/              # Backend NestJS
│   ├── src/admin/    # Provisioning tenant (platform admin)
│   ├── src/products/ # Catalogo, CSV import/export
│   ├── src/inventory/ # Giacenze, movimenti, CSV
│   ├── src/shopify/  # OAuth, sync, webhook, rate limit
│   └── prisma/       # Schema e migration PostgreSQL
├── docs/             # Guide Markdown + HTML/PDF
├── public/guide/     # Guida utente in-app (pubblica)
├── src/assets/guide-admin/ # Guida tecnica (solo route admin)
└── scripts/         # generate-guide-*, check-rls, environment prod
```

Alias TypeScript: `@core/*`, `@shared/*`, `@features/*`, `@env/*`.

5. Ambiente di sviluppo locale

Requisiti

- Node.js **22** LTS (`.nvmrc`)
- npm (lockfile committato)
- Progetto Supabase (URL + anon key + service role per API)
- Account Shopify Partners (app custom) per test OAuth

Avvio

```
# Frontend (porta 4200)
npm install
npm start

# Backend (porta 3000)
cd api
cp .env.example .env # compilare variabili
npm install
npx prisma migrate dev
npm run start:dev
```

Shopify in locale

Shopify richiede URL **pubblici** per OAuth callback e webhook. Usa **ngrok** o **cloudflared**:

1. Tunnel verso `localhost:3000`
2. Imposta `SHOPIFY_APP_URL` e `FRONTEND_URL` nel `api/.env`
3. Aggiorna redirect URL nell'app Partners

PWA locale

```
npm run build:pwa:local
npm run serve:pwa
```

6. Variabili d'ambiente

Frontend (`.env` → **build**, valori **pubblici**)

Vedi `.env.example` in root:

Variabile	Significato
<code>VESTIFLOW_API_BASE_URL</code>	URL API produzione
<code>VESTIFLOW_SUPABASE_URL</code>	URL Supabase
<code>VESTIFLOW_SUPABASE_ANON_KEY</code>	Anon/publishable key
<code>VESTIFLOW_ENABLE_BARCODE_SCANNER</code>	Feature flag scanner
<code>VESTIFLOW_ENABLE_SHOPIFY</code>	Feature flag integrazione Shopify UI

Mai service role o secret Shopify nel frontend.

Backend (`api/.env`)

Vedi `api/.env.example` :

Variabile	Significato
DATABASE_URL / DIRECT_URL	PostgreSQL Supabase
SUPABASE_URL , SUPABASE_SERVICE_ROLE_KEY , SUPABASE_JWT_SECRET	Auth e admin DB
CORS_ORIGINS	Origini frontend consentite
SHOPIFY_*	OAuth, scope, cifratura token, rate limit
PLATFORM_ADMIN_EMAILS	Email operatori (virgola)
SUPABASE_PRODUCT_MEDIA_BUCKET	Bucket immagini (product-media)
FRONTEND_URL	Redirect post-OAuth

7. Onboarding nuovo cliente (tenant)

UI: /app/admin/clients/new (solo platform admin).

Procedura

1. **Identificazione** — nome commerciale, ragione sociale opzionale
2. **Anagrafica** — P.IVA, CF, sede, contatti (opzionali)
3. **Primo accesso** — ruolo VestiFlow (owner default), nome, email, password
4. **Setup** — nome negozio e location iniziale (opzionali; default «Negozio principale»)

Il backend crea: tenant, utente Supabase Auth, store, location, profilo utente collegato.

Dopo il provisioning

Consegna credenziali al titolare **in modo sicuro**. Il titolare completa:

1. MFA (consigliato)
2. Collegamento Shopify
3. Sync location + webhook + import catalogo

Modifica tenant esistente

Tabella **Clienti registrati** → click riga → /app/admin/clients/:id .

Modificabile: anagrafica, nome titolare, negozio, location. **Non** email accesso (Supabase Auth) né ruolo utente da UI.

API

Metodo	Path	Azione
GET	/admin/tenants	Lista tenant
POST	/admin/tenants	Crea tenant + primo utente
GET	/admin/tenants/:id	Dettaglio
PATCH	/admin/tenants/:id	Aggiorna anagrafica/setup

Body create include `role` (`owner` | `admin` | `manager` | `clerk`).

8. Autenticazione e ruoli

Flusso auth

1. Login Supabase Auth (frontend)
2. JWT inviato all'API (`Authorization: Bearer`)
3. `JwtAuthGuard` valida firma con `SUPABASE_JWT_SECRET`
4. Profilo utente + `tenantId` + ruolo + `isPlatformAdmin` caricati

Ruoli tenant (UI + API)

Implementati in `tenant-permissions.util.ts` (frontend) e guard analoghi lato API.

Permesso chiave	Ruoli
Shopify sync / import catalogo	owner, admin
CRUD prodotti, CSV catalogo	owner, admin, manager
CSV giacenze, ordini fornitori	owner, admin, manager
Movimenti magazzino, inventario fisico	tutti
MFA settings	owner, admin, manager

Route Angular sensibili: `tenantRoleGuard` + `data.tenantRoutePermission` .

9. Integrazione Shopify (tecnica)

Ownership sync (riepilogo)

Entità	Owner	Note
Prodotti/varianti	Condiviso write-through	Push al save da VestiFlow
Clienti, ordini online	Shopify	Read-only in VF
Giacenze	Condiviso	VF: carichi/rettifiche; Shopify: vendite
Location	Shopify master	Import + mapping
Ordini fornitori	Solo VestiFlow	—

OAuth

- Scope default in `SHOPIFY_SCOPES` (`.env.example`)
- Token cifrati at rest (`SHOPIFY_TOKEN_ENCRYPTION_KEY`)
- Diagnostica scope in Impostazioni: richiesti vs concessi

Webhook

Registrati con **Attiva aggiornamenti automatici**. Idempotenza lato backend per eventi duplicati/out-of-order.

Limiti Shopify Admin API — concetto

Shopify **non addebita le chiamate API** a consumo. Il piano del negozio definisce **quanto velocemente** puoi chiamare le Admin API prima di essere **rallentato** (HTTP **429 Too Many Requests** / throttling). Non esiste un contatore “a pagamento per chiamata”.

VestiFlow usa oggi soprattutto la **REST Admin API** (prodotti, location, inventario, immagini).

Documentazione ufficiale Shopify:

- [Limiti API \(panoramica\)](https://shopify.dev/docs/api/usage/limits) (https://shopify.dev/docs/api/usage/limits)
- [Rate limit REST Admin API](https://shopify.dev/docs/api/admin-rest/usage/rate-limits) (https://shopify.dev/docs/api/admin-rest/usage/rate-limits)

Fasce tipiche REST (piano negozio → velocità massima):

Piano Shopify (indicativo)	REST Admin API
Basic / Grow (Standard)	~ 2 richieste/sec , bucket 40
Advanced	~ 4 richieste/sec , bucket 80
Plus	limiti più alti (fascia Enterprise)

Il header `X-Shopify-Shop-API-Call-Limit` (es. `32/40`) indica quanto del bucket è consumato.

Cosa fa VestiFlow quando si avvicina o supera il limite

Implementazione in `api/src/shopify/`:

Componente	Ruolo
<code>ShopifyRateLimiterService</code>	Throttle per shop prima di ogni richiesta outbound
<code>ShopifyAdminClient.request()</code>	Applica throttle, legge header bucket, retry su 429
<code>ShopifyProductPullService</code>	Mutex import catalogo (un import per tenant alla volta, process-local)

Comportamento:

1. **Intervallo minimo** tra richieste (default 550 ms $\approx$ 1,8 req/s, sotto il limite Basic 2/s).
2. Se `X-Shopify-Shop-API-Call-Limit` $\geq$ soglia (**85%** del bucket), pausa **1 s** prima delle richieste successive.
3. Su **HTTP 429**: legge `Retry-After`, backoff esponenziale, fino a **5** retry; poi errore 429 con messaggio utente: «*Shopify ha limitato temporaneamente le richieste API...*».
4. **Import catalogo**: enrichment leggero (`skipRemoteMetadata: true`, niente costi varianti extra) per ridurre chiamate; **non avviare due import** sullo stesso tenant in parallelo.
5. **Webhook** prodotti/ordini/giacenze: **0 chiamate outbound** — Shopify invia i dati a VestiFlow.

Variabili env (REST outbound):

Variabile	Default	Effetto
<code>SHOPIFY_API_MIN_INTERVAL_MS</code>	550	Pausa minima tra richieste
<code>SHOPIFY_API_MAX_RETRIES</code>	5	Retry su HTTP 429
<code>SHOPIFY_API_BUCKET_HIGH_WATERMARK</code>	0.85	Pausa se secchio pieno
<code>SHOPIFY_API_BUCKET_PAUSE_MS</code>	1000	Durata pausa secchio

Nota deploy: il rate limiter Shopify è **process-local**. Con più repliche Railway ogni istanza ha il proprio contatore (comportamento conservativo, non centralizzato).

Chiamate indicative per operazione:

Operazione	Chiamate Shopify (ordine di grandezza)	Note
Import catalogo (Shopify → VF)	~4 per 1000 prodotti (pagine da 250)	Lento con cataloghi grandi: normale
Webhook prodotti/giacenze/ordini	0 outbound	Event-driven
Push prodotto al save (VF → Shopify)	1–N per prodotto	Dipende da immagini/varianti
Push giacenza dopo movimento	~1 per movimento	Write-through inventario
Sync location	1	Trascurabile

Cosa fare se un cliente vede errori 429:

1. Non ripremere import/sync in loop — attendere 1–2 minuti e **un solo** retry.
2. Evitare import catalogo + sync massivo contemporanei sullo stesso negozio.
3. In Railway, verificare env rate limit (non abbassare `SHOPIFY_API_MIN_INTERVAL_MS` sotto 500 ms su piani Basic).
4. Cataloghi molto grandi: l'import può richiedere diversi minuti; il backend riprova da solo fino al limite retry.

Non ancora implementato (roadmap): coda lavori persistente in background per bulk multi-tenant; oggi le operazioni massicce sono serializzate per shop/tenant ma restano sincrone nella request HTTP.

Rate limiting (REST Admin API) — riferimento rapido env

Vedi tabella variabili sopra. Valori in `api/.env.example`.

Import catalogo: enrichment ridotto (`skipRemoteMetadata`) + mutex un import per shop.

Troubleshooting `read_products`

1. App Partners: versione attiva include `read_products` , `read_inventory`
2. `SHOPIFY_API_KEY` Railway = Client ID app
3. Disinstalla app dal negozio Shopify
4. Disconnetti + riconnetti in VestiFlow
5. Verifica riga **Catalogo prodotti** → **Lettura** in Impostazioni

Protected customer data

Ordini/clienti webhook possono richiedere approvazione Partners. Catalogo/giacenze non dipendono da questo.

10. Supabase: database, Auth, Storage, RLS

Prisma

- Schema: `api/prisma/schema.prisma`
- Migration: `npx prisma migrate dev` (locale), deploy in CI/CD API

RLS obbligatoria

Ogni tabella business deve avere RLS attiva. CI esegue `scripts/check-rls.mjs` (workflow `.github/workflows/security.yml`) con anon key: **zero righe** leggibili.

Storage

- Bucket `product-media` public per immagini prodotto
- Upload via API (sharp/metadata strip lato server se configurato)

Auth

- Utenti creati al provisioning (`admin-tenants.service`)
 - MFA: Supabase TOTP, UI in Impostazioni
-

11. Dominio dati principale

Entità	Note
Tenant	Azienda cliente
User	Profilo app, tenantId , ruolo
Store / Location	Store commerciale; location per stock
Product / ProductVariant	Opzioni generiche; SKU univoco
InventoryLevel	variantId × locationId , stati quantità
StockMovement	Audit trail obbligatorio
SupplierOrder	Solo VF
SalesOrder / Customer	Import Shopify, read-only UI
ShopifyConnection	Token, scope, stato sync per tenant

Denaro: **interi minor units** (Money.amountMinor), mai float.

12. API e permessi tenant

Base URL: /api/v1 . Header Authorization obbligatorio (salvo health).

Rate limiting API VestiFlow (NestJS)

Separato dai limiti Shopify: protezione anti brute-force / DoS sull'**API propria**.

Parametro	Valore	Dove
Limite globale	300 richieste / minuto / IP	ThrottlerModule in api/src/app.module.ts
Guard	ThrottlerGuard su tutte le route	Eccetto route marcate @Public()
Webhook Shopify inbound	Esclusi dal throttling globale	shopify-webhooks.controller.ts — non perdere eventi legittimi

Se un client supera 300 req/min riceve **429**; il frontend lo mappa in AppError kind rate_limited («Troppe richieste, riprova tra poco»).

Pattern service NestJS:

- Validazione DTO (`class-validator`)
- Filtro `tenantId` da JWT
- Errori → messaggi utente in italiano dove applicabile

Frontend: `HttpClient` + interceptor auth/error; mock disabilitati in prod.

13. Import ed export CSV

Catalogo prodotti

Export	<code>GET /products/export/csv</code> — formato Shopify CSV
Import	<code>POST /products/import/csv</code> — preview + commit
UI	Prodotti → Esporta / Importa CSV
Permessi	manager+

Giacenze

Export	<code>GET /inventory/levels/export/csv</code>
Import	<code>POST /inventory/levels/import/csv</code> — rettifiche
Colonne import	SKU, Location (nome esatto), Disponibile
UI	Magazzino → Giacenze
Permessi	manager+

Vendite e clienti

Export CSV dalle liste (filtri rispettati). Sync manuale Shopify: owner/admin.

14. Scanner barcode

- Componente: `shared/components/barcode-scanner` (BarcodeDetector API)
- Flag: `VESTIFLOW_ENABLE_BARCODE_SCANNER`
- Schermate: Cerca giacenza, Giacenze, Registra movimento, Inventario fisico, Prodotti
- Lookup API: `GET /products/variants/by-code/:code` (SKU o barcode esatto)

- Fallback iOS: input manuale

15. Generazione guide (HTML/PDF)

```
npm run docs:guide:all
```

Genera:

Output	Contenuto	Audience
public/guide/content.html	Solo guida utente	Tutti (/app/guide)
public/guide/vestiflow-guida.pdf	PDF utente	Download pubblico in-app
src/assets/guide-admin/content-tecnica.html	Solo guida operatore/tecnica	Platform admin
src/assets/guide-admin/vestiflow-guida-tecnica.pdf	PDF tecnico	Download admin
docs/GUIDA-*.html/pdf	Sorgenti in repo	Documentazione offline

Markdown sorgenti:

- docs/GUIDA-UTENTE-VESTIFLOW.md
- docs/GUIDA-OPERATORE-VESTIFLOW.md

Dopo modifica guide: **rigenerare** e committare HTML/PDF prima del deploy.

16. Build, test e CI

Frontend

```
npm run lint
npm run build          # pre-push hook
ng test                # Vitest
```

Backend

```
cd api && npm run lint && npm run build
```

CI GitHub Actions

- `security.yml` : check RLS Supabase (set secrets `SUPABASE_URL` , `SUPABASE_ANON_KEY`)

Estendere pipeline con lint + test + build su PR (best practice repo rules).

17. Deploy produzione

Frontend

1. Imposta env build (`VESTIFLOW_API_BASE_URL` , Supabase anon, flags)
2. `npm run build`
3. Deploy `dist/vestiflow` su Firebase App Hosting
4. `CORS_ORIGINS` API deve includere dominio frontend

Backend

1. Railway (o altro): env da `api/.env.example`
2. `prisma migrate deploy` in release
3. Verifica `PLATFORM_ADMIN_EMAILS` con la tua email operatore
4. `SHOPIFY_APP_URL` = URL API pubblico HTTPS

Post-deploy smoke test

- ☐ Login tenant test
 - ☐ Platform admin → Nuovo cliente (staging)
 - ☐ OAuth Shopify su tenant test
 - ☐ Import catalogo + webhook
 - ☐ Upload immagine prodotto
 - ☐ Guida utente + guida tecnica admin
-

18. Sicurezza e checklist pre-release

- ☐ Nessun secret in git (`.env` gitignored)
- ☐ RLS attiva su tutte le tabelle (`npm run check:rls` se script root)
- ☐ `PLATFORM_ADMIN_EMAILS` limitato a operatori fidati
- ☐ CORS ristretto ai domini produzione

- ☐ Token Shopify cifrati; revoca su disconnessione
- ☐ MFA disponibile per admin negozio
- ☐ Dipendenze: `npm audit` senza high/critical
- ☐ Guide rigenerate se modificate

19. Troubleshooting tecnico

Problema	Azione
<code>isPlatformAdmin</code> false in UI	Verifica email in <code>PLATFORM_ADMIN_EMAILS</code> , ri-login
403 su <code>/admin/tenants</code>	Stesso controllo email lato API
CORS error	Aggiungi origin frontend a <code>CORS_ORIGINS</code>
JWT invalid	Allinea <code>SUPABASE_JWT_SECRET</code> con dashboard Supabase
Webhook non arrivano	URL tunnel/prod raggiungibile; HTTPS; webhook registrati
Import catalogo 429 / throttling Shopify	Attendi 1–2 min; non parallelizzare import; vedi §9 limiti Shopify; controlla env <code>SHOPIFY_API_*</code>
API VestiFlow 429 (troppi click)	Limite 300 req/min/IP; chiedi al tenant di non ripetere azioni in loop
Immagini 404	Bucket <code>product-media</code> esiste ed è public
Anon key legge dati	Critico — RLS mancante, fix migration immediato

20. Limitazioni note e roadmap

Area	Stato
Multi-store commerciali in un tenant	Non supportato — un shop = un tenant
Invito utenti / cambio ruolo self-service	Non in UI — solo provisioning iniziale + richiesta operatore
Location manuale senza Shopify	Parziale (location onboarding); sync Shopify consigliato
Cassa / corrispettivi IT nativi	Non previsti — Shopify POS
Report server-side avanzati	In evoluzione
Coda bulk Shopify persistente (multi-tenant)	Non implementata — operazioni massicce sincrone HTTP
Notifiche email custom reset password	Config Supabase

Contatti

Manutenzione prodotto: **proprietario VestiFlow** (questo documento è il riferimento operativo interno).